



THINKST  
**SCAPES**

**Q4 • 2022**  
<https://thinkst.com/ts>

**Brought to you by**



**Most companies find out way too late  
that they've been breached.**

*Thinkst Canary changes this.*

Canaries deploy in under 4 minutes  
and require 0 ongoing admin overhead.

They remain silent until they need to chirp,  
and then, you receive that single alert.

When.it.matters.

Find out why some of the smartest security teams  
in the world swear by Thinkst Canary.

<https://canary.love>



# Contents

|                                                                                            |           |
|--------------------------------------------------------------------------------------------|-----------|
| <b>Introduction</b>                                                                        | <b>4</b>  |
| <b>Themes covered in this issue</b>                                                        | <b>5</b>  |
| <b>Signature validation at scale, for better or worse</b>                                  | <b>6</b>  |
| Hacking the Cloud with SAML                                                                | 7         |
| Announcing GUAC, a great pairing with SLSA (and SBOM)!                                     | 8         |
| We sign code now                                                                           | 9         |
| <b>Modern post-exploitation</b>                                                            | <b>10</b> |
| Knockout Win Against TCC, a.k.a. 20+ NEW Ways to Bypass Your MacOS Privacy Mechanisms      | 11        |
| Farming The Apple Orchards: Living Off The Land Techniques                                 | 12        |
| LOLBINed – Using Kaspersky Endpoint Security “KES” Installer to Execute Arbitrary Commands | 13        |
| POPKORN: Popping Windows Kernel Drivers At Scale                                           | 14        |
| <b>Forgotten legacy in today’s systems</b>                                                 | <b>15</b> |
| RC4 Is Still Considered Harmful                                                            | 16        |
| Kerberos’ RC4-HMAC broken in practice: spoofing PACs with MD5 collisions                   | 16        |
| Exploring Ancient Ruins to Find Modern Bugs: Discovering a 0-Day in MS-RPC service         | 17        |
| Decentralized Identity Attack Surface                                                      | 18        |
| <b>Nifty Sundries</b>                                                                      | <b>19</b> |
| Drone Authentication via Acoustic Fingerprint                                              | 20        |
| On the Implications of Spoofing and Jamming Aviation Datalink Applications                 | 21        |
| {JS-ON: Security-OFF}: Abusing JSON-Based SQL Queries                                      | 22        |
| Are There Wireless Hidden Cameras Spying on Me?                                            | 23        |
| <b>Conclusion</b>                                                                          | <b>24</b> |

# Introduction

*Welcome to the Q4, 2022 edition of ThinkstScapes! This issue focuses on content released, published, or presented between the first of October and the end of December, 2022.*

This quarter, surprisingly, showed a decline in the number of conferences, talks and blog posts as the holidays and the cancellation of the Chaos Computer Congress pushed research releases into the new year. Q1, 2023 is looking like a return to the regular frenetic pace, with a number of high-quality conferences lined up.

As a reminder: If you are aware of work we've missed, a blog post we should have seen or a conference we should have covered, we'd love to hear about it. Please send them to **ts@thinkst.com!**

**This issue includes talks drawn from the following conferences (and over 1,250 security blog posts):**

| Conference/venue name | Number of publications reviewed |
|-----------------------|---------------------------------|
| Hacktivity            | 38                              |
| Objective by the Sea  | 20                              |
| Hexacon               | 16                              |
| No Hat Con            | 9                               |
| SAINTCON              | 111                             |
| CODE BLUE             | 24                              |
| Hack.Sydney           | 18                              |
| Ekoparty              | 40                              |
| POC'22                | 21                              |
| BlackAlps             | 14                              |
| m0leCon               | 13                              |
| Blackhat EU           | 45                              |
| ACSAC                 | 73                              |
| <b>Total</b>          | <b>442</b>                      |





# Themes covered in this issue



## SIGNATURE VALIDATION AT SCALE, FOR BETTER OR WORSE

Papers in this theme explored cloud-scale signatures for verifying identity and software provenance. One talk discovered several weaknesses in the software underpinning SAML authentication, while the others focused on scalable ways to use signatures to verify code supply chains.

## MODERN POST-EXPLOITATION

This theme covers work exploring post-exploitation on MacOS in a TCC world, the process for discovering and abusing living off the land binaries (LOLBins), and what these look like on modern MacOS systems. Finally, this theme wraps with a new automated vulnerability discovery tool in signed Windows drivers to bring your own escalation of privilege.

## FORGOTTEN LEGACY IN TODAY'S SYSTEMS

Research in this theme showcases how, even in modern systems, there can be ample legacy attack surface, including deprecated cryptography schemes and MS-RPC security bypasses. This theme wraps up with a paper on a modern web3 system that was vulnerable to a very legacy bug class – a powerful reminder to keep the basics covered while trying to innovate.

## NIFTY SUNDRIES

As always, some work stood out as top-notch for inclusion, but did not fit into any of the aforementioned themes. This quarter we see research into aviation security, generic WAF bypasses, and a clever way to detect and localise Wi-Fi spy cameras.



# Signature validation at scale, for better or worse

- ✓ *Hacking the Cloud with SAML*
- ✓ *Announcing GUAC, a great pairing with SLSA (and SBOM)!*
- ✓ *We sign code now*





# Hacking the Cloud with SAML

**Author:** Felix Wilhelm



[Slides](#)



[Video](#)



*This research explored not the protocol's security itself (past work has looked at techniques to bypass SAML), but rather the exposed attack surface on the IdP and SP servers.*

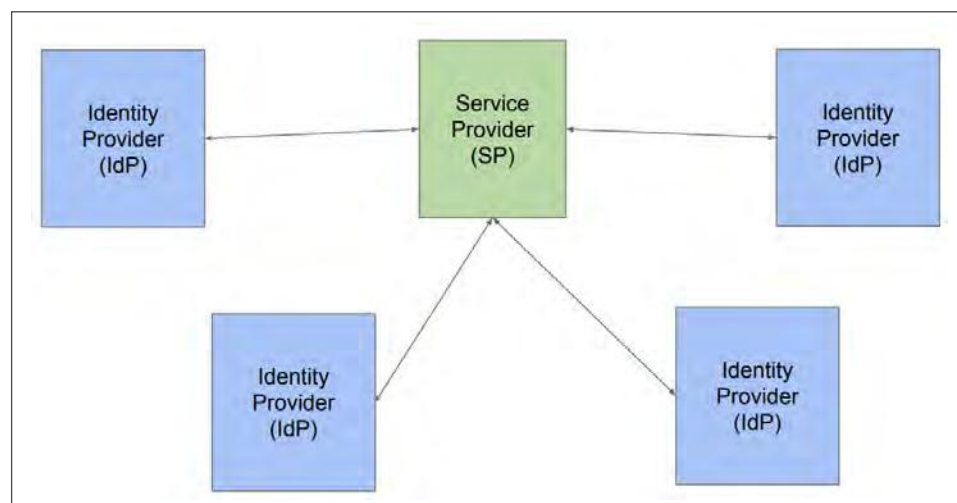
**Figure 1.** A figure showing the opposite relationship between service and identity providers in a cloud environment, as opposed to a legacy enterprise model (with one IdP and many SPs).

Security assertion markup language (SAML) is the underlying process and protocol for allowing an identity provider (IdP) to attest your identity to a service provider (SP), with the client acting as a go-between for the providers. SAML was originally designed for enterprise environments to support single sign-on where one IdP (e.g., Active Directory) would support a client logging into multiple internal or external services. Modern cloud infrastructures change that, where a single SP will support multiple, or even custom IdPs in order to provide a seamless end-user experience.

Because the client acts as a go-between, both types of providers need to accept inputs from any possible client, exposing an attack surface to anyone. This research explored not the protocol's security itself (past work has looked at techniques to bypass SAML), but rather the exposed attack surface on the IdP and SP servers. These services run complicated XML translations before they validate the identity of the signer, allowing for arbitrary messages to explore deep code paths in the XML and signature validation libraries. A number of vulnerabilities are detailed, covering a number of CWE types and thereby highlighting the risks across the ecosystem.

## TAKEAWAYS:

- ✓ **The use of SAML** for both enterprise and cloud authentication schemes upends the assumptions on which entities are trustworthy. To provide functionality for both schemes, each provider must operate under the assumption that all requests are untrusted, yet much of the software was written prior to these changes. Adding in the complexity of XML translations and digital signature schemes indicates that this space will continue to be a popular spot for bugs with far-reaching consequences.



# Announcing GUAC, a great pairing with SLSA (and SBOM)!

**Authors:** Brandon Lum, Mihai Maruseac, Isaac Hepworth, Google Open Source Security Team



[Blog](#)



[Code](#)



[Video](#)

With the ever-present concern over software security, and specifically software supply chain security, Google announced an Open Source project named GUAC, or Graph for Understanding Artifact Composition. Using GUAC, teams may be able to answer questions at three important stages of software supply chain security – Proactive, Preventative, and Reactive. To understand something complex like the blast radius of a vulnerability, teams need to trace the relationship between a component, and everything else in the portfolio. GUAC aggregates and synthesises software security metadata at scale and makes it meaningful and actionable.

## TAKEAWAYS:

- ✓ **We are hopeful** looking at the aspirations of this project. Giving teams the ability to quickly answer questions about exposure and impact of a vulnerability enables them to rapidly work to remediate and recover from large supply chain issues.
- ✓ **By now, teams may be getting tired and distracted** by the “am I affected by X vulnerability?” question. However, as supply chain attacks become more sophisticated, answering just this question is insufficient and becoming increasingly difficult. As teams start to ask, “If X was compromised, which software is affected?”, we hope to see a tool like GUAC help inform architecture and design, as well as guide incident response.

Figure 2. GUAC seeks to help teams answer questions across various stages.





# We sign code now

**Author:** William Woodruff

 [Blog](#)

 [Code](#)

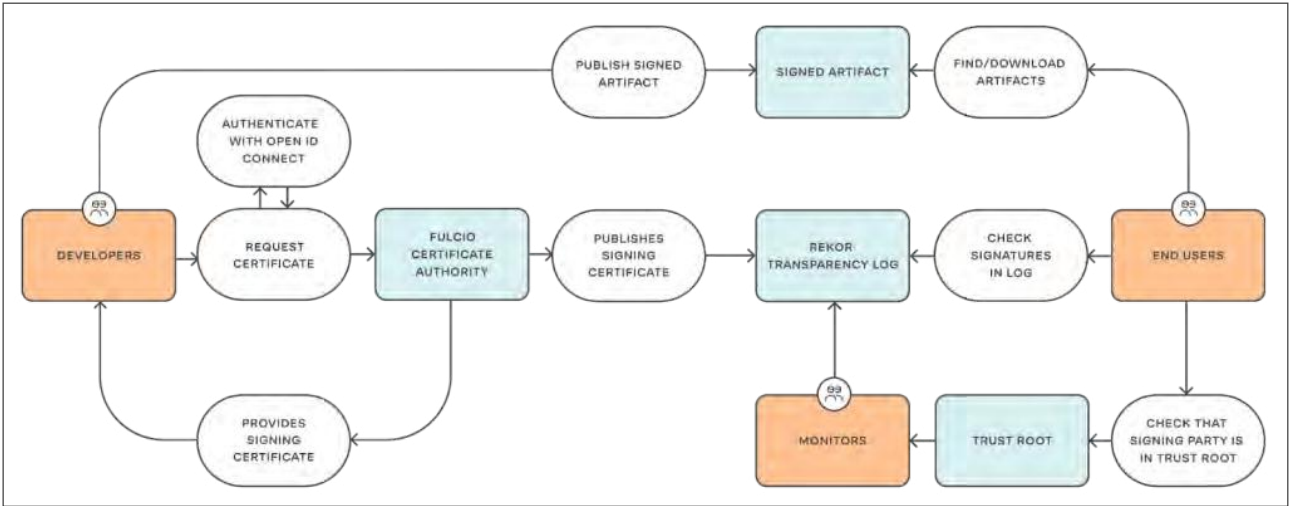
 [Video](#)

This blog covers the SigStore project, specifically the Python-language implementation. SigStore allows developers to tie short-lived certificates to their GitHub, Google, etc. accounts and sign code or other artefacts with those certificates. This reduces the risk of a certificate being exposed, while also storing a record of the human identity associated with a specific signature. This has been extended into CI/CD build systems (e.g., GitHub actions) to allow for machines to also sign their output and tie it to the official build system versus an attacker’s.

**TAKEAWAYS:**

- ✓ **SigStore is filling a gap** with current software bill-of-materials (SBoM) systems, in that it ties software to the developers who release it, and even the CI/CD infrastructure that built it. This adds in a tighter link between the presence of an entry in an SBoM record and the actual code present. SBoMs still must go further to encapsulate the build systems, their configuration, and even aspects of the resultant binaries, in order to truly realise their claims.

Figure 3. A high-level diagram of the components of SigStore and how they interact.



# Modern post-exploitation

- ✓ *Knockout Win Against TCC, a.k.a. 20+ NEW Ways to Bypass Your MacOS Privacy Mechanisms*
- ✓ *Farming The Apple Orchards: Living Off The Land Techniques*
- ✓ *LOLBINed – Using Kaspersky Endpoint Security “KES” Installer to Execute Arbitrary Commands*
- ✓ *POPKORN: Popping Windows Kernel Drivers At Scale*



# Knockout Win Against TCC, a.k.a. 20+ NEW Ways to Bypass Your MacOS Privacy Mechanisms

**Authors:** Csaba Fitzl  
and Wojciech Reguła



[Slides](#)

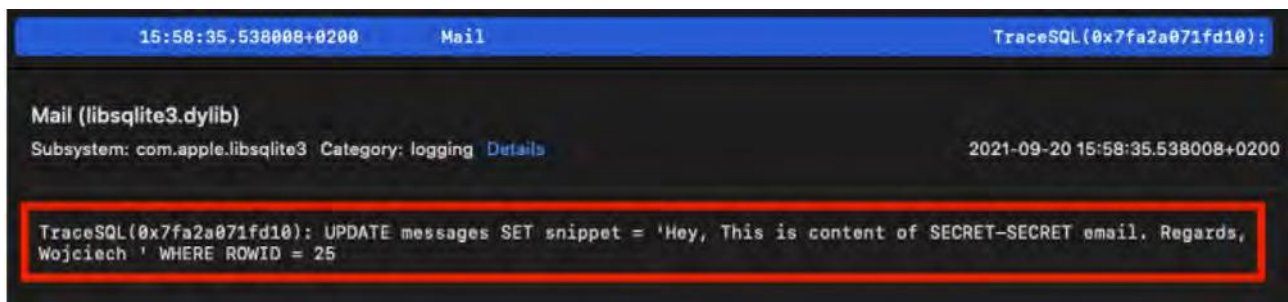
This work explores Apple's new restrictions in its MacOS operating system: TCC (Transparency, Consent, and Control). TCC provides a more fine-grained entitlement system to limit the data available to each application. For example, a photo editing application cannot access the user's email, despite running from the same user context. Since 10.13, TCC has aimed to protect more portions of the system, from full disk access to the camera or clipboard.

The researchers looked for ways to bypass TCC on a MacOS system, as a post-exploitation step, as TCC protects user data even against a user with root permissions. They were able to find over 20 bypasses through loading plugins in Apple applications that had a number of entitlements, enabling in-built tracing and debugging logs, and even using Apple's backup and restore utility to create a copy of the filesystem without the TCC entitlements. The work finishes with a review of the changes made in MacOS Ventura, and how some of the fixes are not entirely comprehensive.

## TAKEAWAYS:

- ✓ **While TCC does give users more control** over the data that applications can access, it is clear that, like Microsoft's User Account Control, trying to add restrictions to a previously-permissive environment is going to be difficult. There is a balancing act between inducing popup fatigue in users and closing these leaks; TCC will take a long time to become robust enough to protect against a malicious actor.

*Figure 4. An example of bypassing TCC by setting an environment variable to log SQLite queries.*



# Farming The Apple Orchards: Living Off The Land Techniques

**Authors:** Cedric Owens  
and Chris Ross



[Slides](#)



[Video](#)

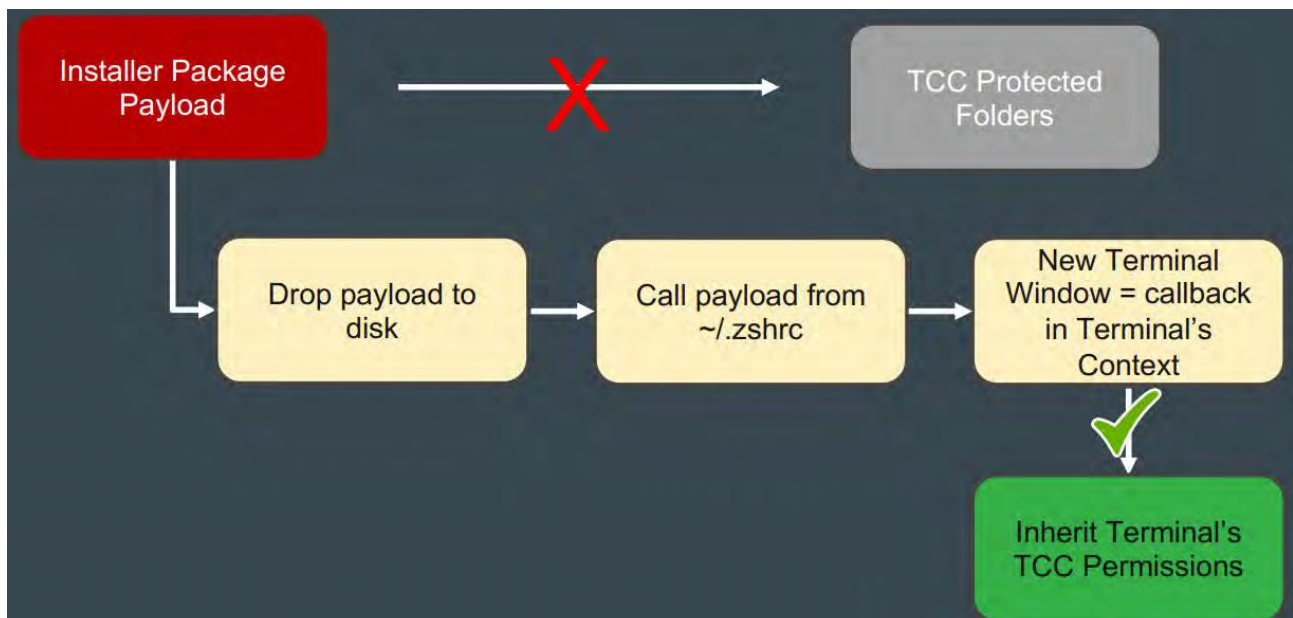
Living off the land is a post-exploitation technique used to minimise or eliminate the need to download and run third-party software onto a target system, while continuing the attack campaign. Using OS-default binaries (LOLBins) to replicate the needed features allows an attacker to avoid triggering alerts for suspicious file execution, as LOLBins are typically signed and trusted by the OS vendor that publishes them.

This research explored living off the land in Apple's MacOS environments. Modern MacOS systems include additional protections known as TCC, or Transparency, Consent, and Control, to limit an application's ability to access sensitive data (e.g., photos or documents). Without running within a fully-trusted TCC context, even with code execution, an attacker may not be able to access any user data. This research showed how to use existing OS features to bypass or circumvent the TCC protections, by browsing data through the Spotlight search database, and injecting a payload into a legitimate application (e.g., lldb) that will run it with its more trusted TCC context.

## TAKEAWAYS:

- ✓ **Living off the land** has been a primarily Windows-focused pursuit, due to the relative lack of built-in capabilities. As Windows becomes more feature-filled by default, and other OS environments restrict the abilities of their built-in software, expect to see more research emphasis on non-Windows environments.

*Figure 5. A flowchart showing how to bypass TCC by using Terminal.app's context.*





# LOLBINED – Using Kaspersky Endpoint Security “KES” Installer to Execute Arbitrary Commands

**Author:** Nasreddine Bencherchali



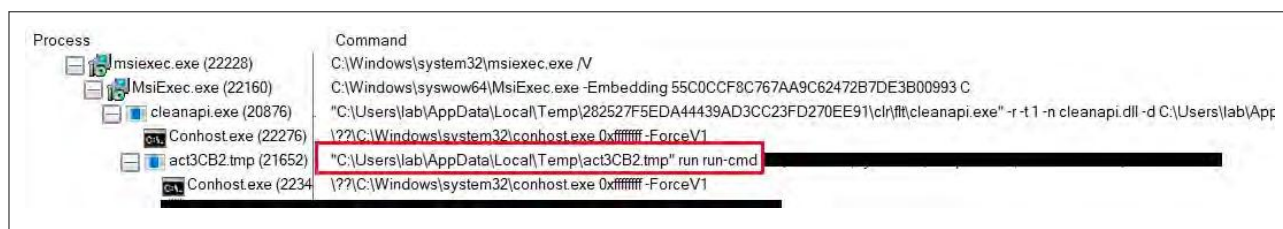
[Blog](#)

LOLBins are binaries already trusted by the local operating system, which can be used to camouflage their malicious activity. In this post, the author details an approach to finding ways to execute code from Kaspersky's installer. The author found that he could use the signed binaries extracted from “kavremover.exe” or “cleanapi.dll”, to execute arbitrary commands (some of these commands require Administrator privileges). This approach could offer an interesting setup for attackers who might stumble upon organisations that are already running Kaspersky; this could be used to execute commands coming from an already trusted Kaspersky process or installer.

## TAKEAWAYS:

- ✓ **This post demonstrates a number of tools**, and a methodology, that other researchers can use to find unexpected behaviour in already trusted and existing applications. We can likely continue to see the trend of more applications' features being usurped to hide malicious activity.
- ✓ **These patterns of abuse** will continue to emerge as attackers are often more interested in what an application can be made to do and operate on the principle that "any action not specifically denied, is allowed".

*Figure 6. A screenshot of the process tree under the Kaspersky installer, allowing for command injection.*



# POPKORN: Popping Windows Kernel Drivers At Scale

**Authors:** Rajat Gupta,  
Lukas Dresel, Noah  
Spahn, Giovanni Vigna,  
Christopher Kruegel,  
and Taesoo Kim



[Paper](#)



[Code](#)



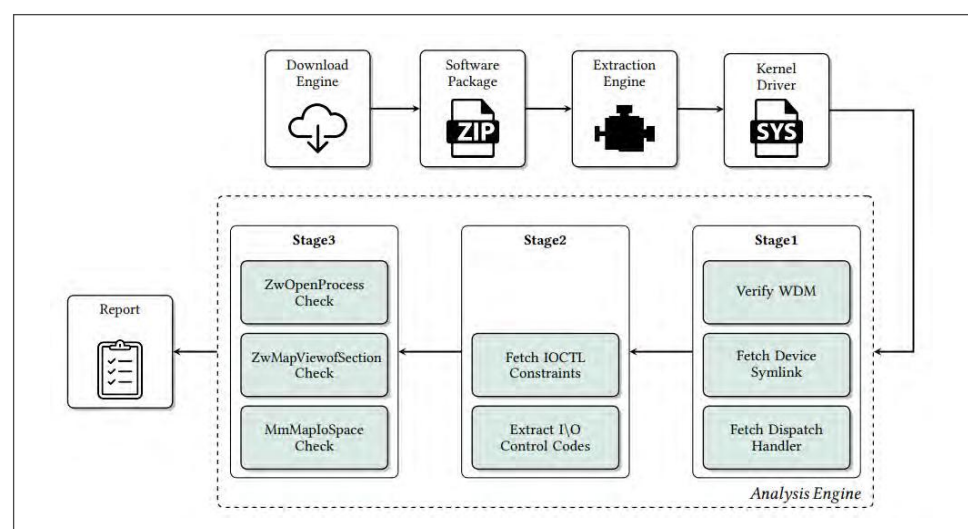
The presented system, POPKORN, downloaded and extracted 5,000 driver binaries, then used angr to search for paths between a user-space call and one of the three kernel functions that were commonly associated with an EoP exploit.

This research explored ways to automatically examine signed Windows drivers for a class of vulnerability commonly used to achieve escalation of privilege (EoP) attacks. When untrusted user-space data is passed to the driver that fails to sufficiently sanitise that data before calling certain kernel functions, a process can access arbitrary physical memory, gain control over other processes, and corrupt or subjugate them. There are many signed drivers in the wild for almost every hardware device, and by using vulnerabilities in these drivers, malware is able to gain kernel access.

The presented system, POPKORN, downloaded and extracted 5,000 driver binaries, then used angr to search for paths between a user-space call and one of the three kernel functions that were commonly associated with an EoP exploit. Of the 5,000 drivers, only 212 were compatible with the vulnerability definition (WDM driver, took user-space data, called to one of the sink functions), and of these, POPKORN identified 38 vulnerabilities, 31 of which were new, and all were manually verified as true-positives. The CVE and disclosure processes were underway at time of publication, but the POPKORN system showed a performant approach (averaging under 7 seconds per driver) to look for these deep and impactful vulnerabilities.

## TAKEAWAYS:

- ✓ **This work highlights the trend** of vulnerability research becoming increasingly automated for deeper bugs in binary-only targets. As more bug classes become codified as a vulnerability definition, it will be harder for those types of issues to slip through automated analysis of code being published.
- ✓ **Years after DARPA's Cyber Grand Challenge (CGC)** gave a budget and incentives to jumpstart vulnerability hunting automation, it is still paying dividends. While CGC itself was focused on an artificial environment, the tools built for the competition are showing real-world benefits.



**Figure 7.** A diagram showing the high-level design and flow of the POPKORN system.



# Forgotten legacy in today's systems

- ✓ *RC4 Is Still Considered Harmful*
- ✓ *Kerberos' RC4-HMAC broken in practice: spoofing PACs with MD5 collisions*
- ✓ *Exploring Ancient Ruins to Find Modern Bugs*
- ✓ *Decentralized Identity Attack Surface*



## RC4 Is Still Considered Harmful

## Kerberos' RC4-HMAC broken in practice: spoofing PACs with MD5 collisions

Both researchers point out weaknesses within the Windows Kerberos implementation, which still allows for legacy protocols. In the blog by James Forshaw, he developed two attacks: the first attack is network-based to alter an unprotected field, creating a downgrade to RC4 MD4 encryption, then compromising the user's TGT session key resulting in Elevation of Privileges (EoP). The second variation of the attack leverages a weakness in Microsoft's ASN.1 library to develop a feasible brute force approach, which did not require access to network authentication traffic, and still resulted in EoP.

The paper outlines a method for using MD5 collisions to forge the Privileged Attribute Certificate. This attack also shows that reliance on the MD5 hash function has not yet been fully eliminated from modern critical systems, and that hash collision attacks can still be used as part of a practical exploit.

### TAKEAWAYS:

- ✓ **Older legacy protocols** continue to linger in critical systems. Challenges within organisations to support legacy software and authentication will continue to burden teams trying to secure their networks from these kinds of focused, well-planned exploits.
- ✓ **ASN.1 parsing is difficult** and has a history of vulnerabilities and exploitation. Until there are better models for recognising and parsing network information, vulnerabilities will continue to crop up in both new software using ASN.1 and the legacy tail.
- ✓ **Active Directory security** relies on legacy crypto protocols that are very hard to modify or eliminate. Teams will want to ensure they have enabled mitigations and removed legacy protocol choices where they can.

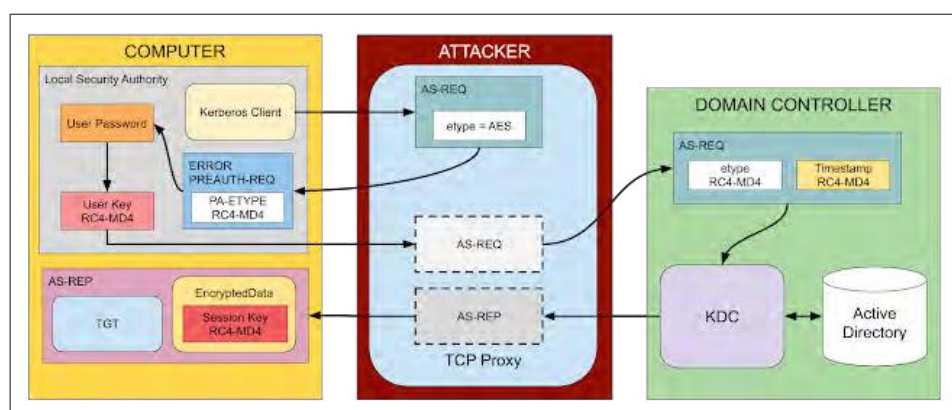


Figure 8. A network attack that could interpose on the Kerberos network traffic.



# Exploring Ancient Ruins to Find Modern Bugs

**Authors:** Ophir Harpaz  
and Stiv Kupchik



[Slides](#)



[Video](#)

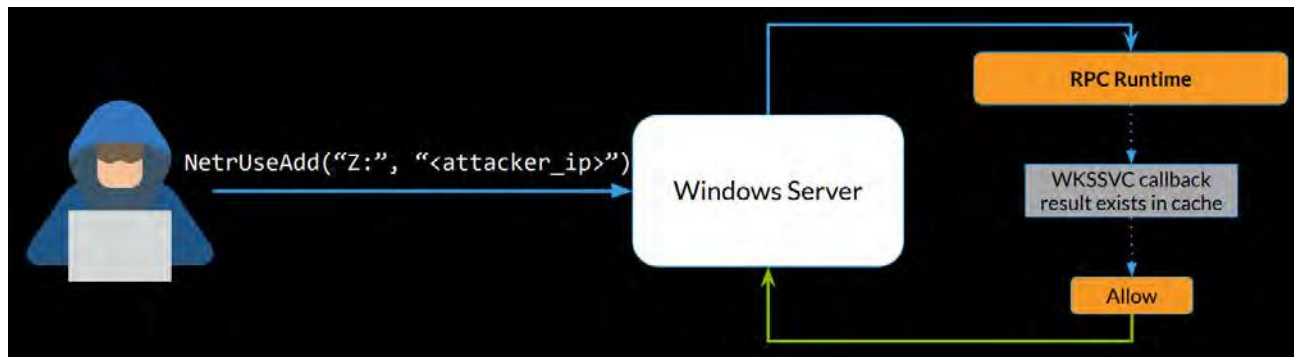
This research explored the mechanics of, and security behind, Microsoft's RPC (MS-RPC) system. MS-RPC dates back to the 1990s, and still plays a vital role in some of their services and OS components. Authentication and authorisation logic were added after initial release, and in order to maintain backwards compatibility, the additional logic adds significant complexity and incomplete coverage.

The researchers built a scanning pipeline that would look for PE files on a Windows system that registers an RPC listener, and try to identify the UUIDs associated with those interfaces. Then, they looked for interfaces that used authentication, but didn't perform a sensitive function, so they would allow remote use. Once that interface was called, it would cache the security authentication context, allowing the attacker to call a more sensitive function without the scrutiny expected. This is demonstrated by a remote attack that allows an attacker to map a file share they control to a remote victim machine, then man-in-the-middle shared file access.

*Figure 9. A diagram showing how an attacker can use pre-cached security authorisations to perform more dangerous operations – mapping a network drive to a server they control.*

## TAKEAWAYS:

- ✓ **RPC services make an attractive target** that is difficult to balance securing against remote abuse and responsiveness. The sheer number of legacy systems that support this promises more weaknesses to come.



# Decentralized Identity Attack Surface

**Author:** Shaked Reiner



[Blog part 1](#)



[Blog part 2](#)

This two-part blog series explored a use of the blockchain to root identity providers. Part 1 explores the beta Microsoft Azure blockchain provider, while Part 2 looks at Sovrin. Each implementation was examined on the axes of decentralisation and implicit trust between a client and the node verifying signatures. In Part 2, the researcher shows a critical vulnerability in the underlying technology behind Sovrin.

Sovrin is implemented in Python, and is well documented and nicely laid out, despite how the vulnerability discovered allowed unauthenticated command injection in any Sovrin node. Even though Sovrin is a permissioned network (only specific nodes can create or validate transactions), the code validating the vulnerable target was not implemented. This vulnerability would have allowed for a complete takeover of the network and the infrastructure on which it ran.

## TAKEAWAYS:

- ✓ **With any new complex distributed system**, there are multiple aspects of security to explore. Much of the focus with blockchain-based systems has been on both the financial risks (flash-lending attacks, etc.) or the cryptographic schemes; this work highlights that the basics must not be forgotten.
- ✓ **The pace of development in this space**, which so highly rewards the first movers, contributes to these types of vulnerabilities. As many of these projects are developed in modern, memory-safe languages, by developers who haven't had experience with legacy C/C++ codebases and their associated security risks, there are more chances for simple things to be overlooked.



*Even though Sovrin is a permissioned network (only specific nodes can create or validate transactions), the code validating the vulnerable target was not implemented.*



# Nifty sundries

- ✓ *Drone Authentication via Acoustic Fingerprint*
- ✓ *On the Implications of Spoofing and Jamming Aviation Datalink Applications*
- ✓ *{JS-ON: Security-OFF}: Abusing JSON-Based SQL Queries*
- ✓ *Are There Wireless Hidden Cameras Spying on Me?*



# Drone Authentication via Acoustic Fingerprint

**Authors:** Yufeng Diao, Yichi Zhang, Guodong Zhao, and Mohamed Khamis



[Slides](#)



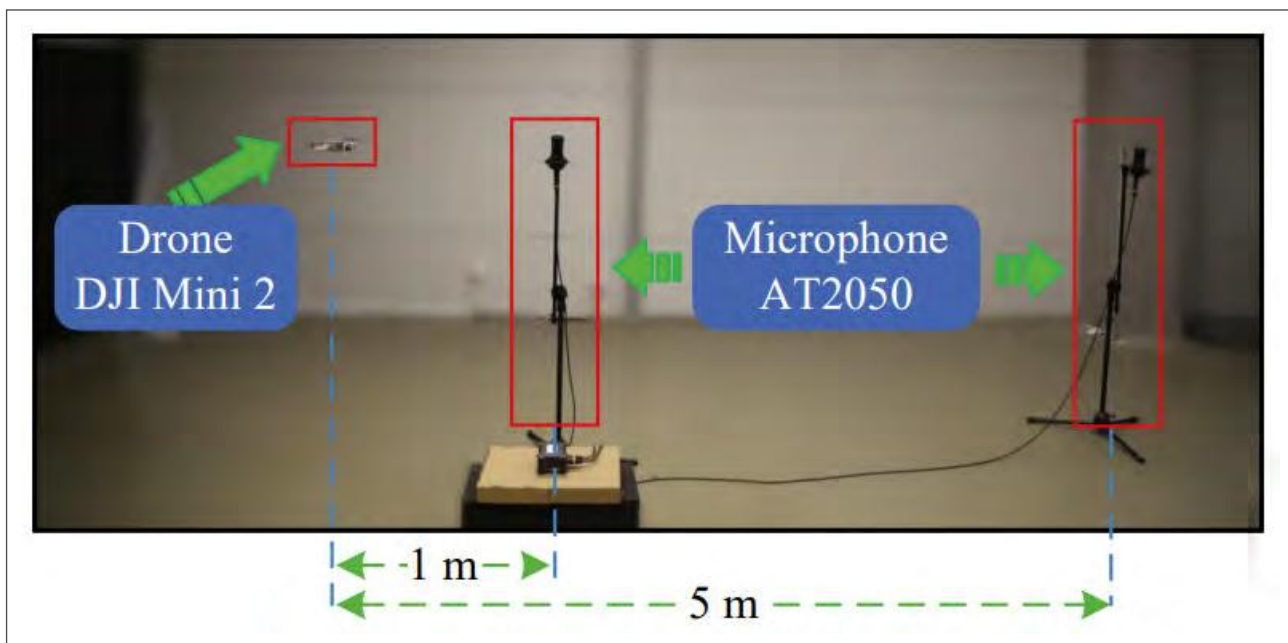
[Paper](#)

This work explored identifying specific drones via an acoustic fingerprint. Eight DJI Mini 2 drones, and multiple sets of spare propellers, were combined to create 24 unique combinations that were recorded in the environment shown in the figure below. Then, multiple analyses were performed on different sample lengths, with or without additional background noise, and different ML model types, to determine which were best at identifying the drone and propeller combination. This was performed in both a closed-world scenario, i.e., one in which all the drones were trained on; and a more realistic open-world where some drones were known, and some were imposters.

## TAKEAWAYS:

- ✓ **With drone costs dropping**, and the number of them in operation rising, questions of how to control airspace and access to private property are increasingly timely. This work shows how a warehouse could perform access control without storing secrets on the device. Even simply detecting the presence of a drone nearby can be coupled with network analysis to minimise fake Wi-Fi AP or other wireless attacks.
- ✓ **Physically unclonable functions** have been a field of study for many years in determining the legitimacy of hardware. The fact that this is being explored via different mediums is exciting and should offer many future benefits.

*Figure 10. A photo of the setup used to collect audio samples from the drones for analysis and fingerprinting.*





# On the Implications of Spoofing and Jamming Aviation Datalink Applications

**Authors:** Harshad Sathaye, Guevara Noubir, and Aanjhan Ranganathan



[Slides](#)



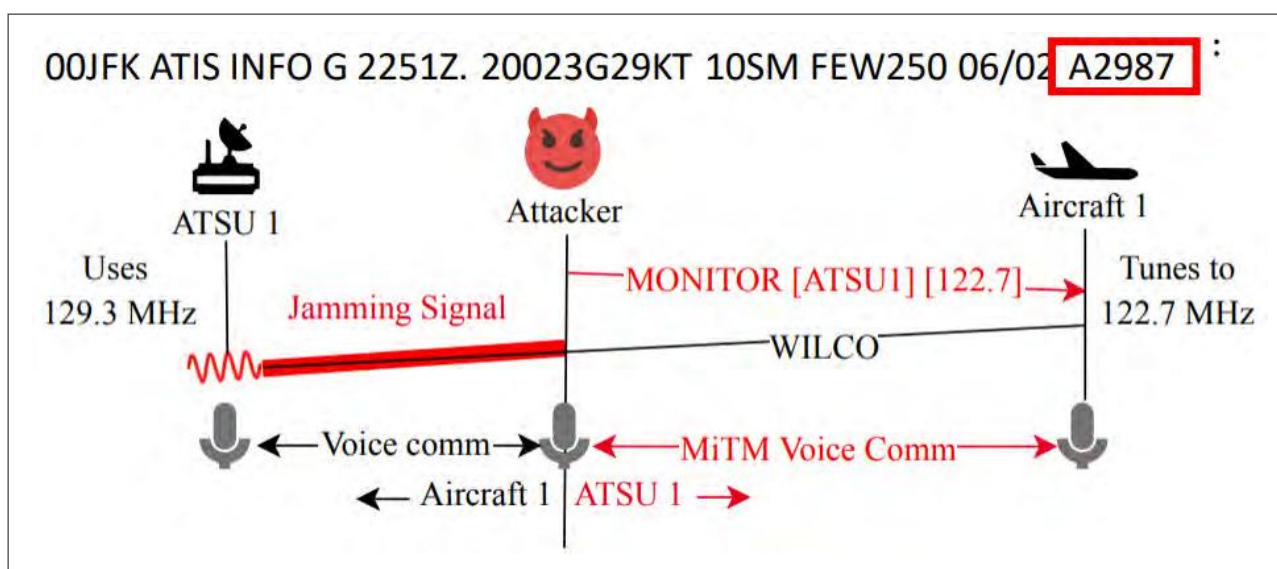
[Paper](#)

This work explored identifying specific drones via an acoustic fingerprint. Eight DJI Mini 2 drones, and multiple sets of spare propellers, were combined to create 24 unique combinations that were recorded in the environment shown in the figure below. Then, multiple analyses were performed on different sample lengths, with or without additional background noise, and different ML model types, to determine which were best at identifying the drone and propeller combination. This was performed in both a closed-world scenario, i.e., one in which all the drones were trained on; and a more realistic open-world where some drones were known, and some were imposters.

## TAKEAWAYS:

- ✓ **While the existence of**, and security issues in, ADS-B are well known, this work shows similar issues with ADS-C, with potentially higher impact. While there is a fallback and humans are in the loop currently, with more autonomous aircraft, the risks here will grow unless additional authentication logic is added. The figure paints a scary picture of how even voice fallback could be subverted.

*Figure 11. An attack diagram showing how an attacker can use the data link to establish a man-in-the-middle position for ATC <-> aircraft communications.*



# {JS-ON: Security-OFF}: Abusing JSON-Based SQL Queries

**Author:** Noam Moshe



[Slides](#)



[Code](#)



[Blog](#)

The majority of this research explored exploiting a specific product's SQLi vulnerability, however, when the researcher tried to exploit the cloud version, it was blocked by AWS' web application firewall (WAF). After exploring the WAF's decisions on which requests to block or allow, it appeared that specific SQL operators were triggering the WAF to drop the request. At this point, the researcher started experimenting with other operators in SQL that may bypass the WAF, and discovered that modern database servers support JSON natively with new operators to simplify JSON comparisons.

Using the new JSON operators bypassed not only the AWS WAF, but all of the large WAF vendors. The researcher developed a patch to SQLMap and was able to trivially detect and exploit SQLi in WAF-protected web applications.

## TAKEAWAYS:

- ✓ **It is always difficult** for security mitigations to be added after, especially when these mitigations operate in the critical path of request performance. This work highlights the challenges of a bump-in-the-wire mitigation when trying to defend against arbitrary injection attacks in a complex and changing environment. Other attacks of this type are expected to catch WAF vendors unaware.

Figure 12. An example of a new operator introduced into PostgreSQL for performing comparisons between JSON objects.

- **PostgreSQL:**

Example Operator: @<

Functionality: left JSON contains

Example:

```
SELECT 1 WHERE '{"b":2}':::JSONB <@ '{"a":1, "b":2}':::JSONB
```



# Are There Wireless Hidden Cameras Spying on Me?

**Authors:** Jeongyoon Heo, Sangwon Gil, Youngman Jung, Jinmok Kim, Donguk Kim, Woojin Park, Yongdae Kim, Kang G. Shin, and Choong-Hoon Lee



[Slides](#)



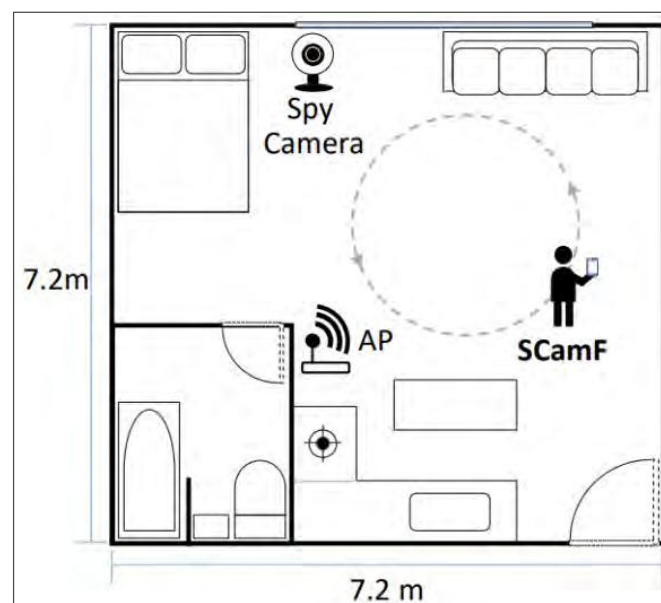
[Paper](#)

A bout of spy cameras, discovered in AirBnBs and hotel rooms, raised the question of how to detect this remote monitoring. In this work, the researchers monitored encrypted Wi-Fi packets in the area being surveyed, to determine whether a sender was a camera, whether it was filming the user, and where, within the space it was located. Their work used two key features to classify devices using a Wi-Fi network: continuous stream of traffic (unlike other devices that may have periods of inactivity) and more traffic sent when the user in the environment was moving (which causes more keyframes to be sent).

An Android app was built that would scan nearby wireless devices during a walk through an environment potentially with a camera present to allow for detection of the camera – with over 97% accuracy. When the user is closer to the camera, more keyframes are needed, allowing the user to determine their proximity to the camera. This process worked across 20 different camera vendors on a network with non-camera devices using the network at the same time to add realism.

## TAKEAWAYS:

- ✓ **This research** has a clear benefit for travellers who would like to look for suspect devices in their private rooms, but there are a number of other use cases that this counter-surveillance capability offers. Further research would have to explore how network segmenting might impact their accuracy, but it's conceivable that this could be used to map out camera locations for many types of locations.
- ✓ **As mentioned** in last quarter's ThinkstScapes, there is a significant amount of sensitive information present just in the packet size for video transmission, despite encryption. The work previously featured explored LTE network traffic, and future work will likely determine whether those techniques would apply to this use case as well.



*Figure 13. The experimental setup showing the location of the camera, wireless access-point, and the user's movement pattern to detect if they were being recorded.*

# Conclusion

*Despite the scaling back of conferences this quarter, quality work still shone through and we thoroughly enjoyed working on this issue.*

## THREE THEMES WERE HIGHLIGHTED IN THIS QUARTER'S EDITION:

1. Trials and tribulations of cloud-scale signature validation.
2. What post-exploitation looks like in more restrictive OS environments.
3. Legacy protocols and bugs in fully up-to-date software.

Next quarter will likely see more content with the holidays behind us. We look forward to diving in, finding interesting work and sharing it with you.



